Title
Decoupling Identity from Access in CI/CD Pipelines: Credential·Broker Patterns for Secure Deployment

---

Abstract
Continuous Integration/Continuous Delivery (CI/CD) pipelines accelerate software delivery but also broaden the

---

1. Introduction
Modern software organisations rely on CI/CD pipelines to achieve rapid, repeatable releases. Automation, howev

---

2. Background

Concept	Description	Key References
Workload Identity (SPIFFE)	Runtime·issued IDs that replace static secrets for CI jobs; contain platfor
Zero·Trust Principles	Emphasise runtime access controls, audit logging, and minimisation of long·lived
Credential Broker	A policy·aware mediator (e.g., Open Policy Agent, Amazon·Cedar) that evaluates SPIFF
Alternative CI/CD Security Mechanisms	Secret·manager injection, GitHub OIDC token flow, HashiCorp Vaul

The broker model cleanly separates **identity issuance** (handled by the platform) from **access fulfillment**

---

3. Key Findings

#	Finding	Supporting Evidence
1	Static role bindings become brittle as pipelines scale.	Avirneni·2025, p.·4
2	Credential brokers enable just·in·time, least·privilege access.	Avirneni·2025, p.·5
3	Standing privilege is **reduced**, not eliminated, by broker mediation.	Avirneni·2025, p.·6
4	Policy evaluation can incorporate intent (e.g., release vs. hot·fix) and context (branch, environment).
5	The broker pattern aligns with NSA/CISA guidance on CI/CD security.	NSA & CISA·2023, p.·12

These findings demonstrate that a credential·broker layer